Studio Nx

Backend(FastAPI/Python) 32 — POST /api/v1/auth/login

2026-10-07

Backend(FastAPI/Python) 32 — 라우터 `POST /api/v1/auth/login`

항목	내용
파일	`studionx/backend/app/api/v1/auth.py` (함수 이름 `login`)
작업	P1-05 로그인 — 로그인 API · PRD 01 FR-103 · FR-105 · FR-109
작성	Claude (AI) · 2026-10-07 · 사용자 검토
이전 · 다음	31 리프레시 쿠키 · 33 `POST /auth/refresh`

1. 하는 일

이메일 · 비밀번호를 확인하고, **토큰 두 개**를 나눠서 준다.

```
POST /api/v1/auth/login
{"email": "route.user@example.com", "password": "Abcdef1!", "remember": true}

→ 200
Set-Cookie: snx_refresh=eyJ…(3일); HttpOnly; Max-Age=259200; Path=/api/v1/auth; SameSite=lax
{"access_token": "eyJ…(30분)", "token_type": "bearer", "expires_in": 1800}
```

토큰	어디로	만든 함수
Access (30분)	응답 **본문** → JS 메모리	26
Refresh (3일)	응답 **쿠키** (`HttpOnly`) → JS 는 못 봄	27 · 31

경우	응답
맞음	200 + 위와 같음
비밀번호 틀림 · 없는 이메일 · 탈퇴	401 `INVALID_CREDENTIALS` "Email or password is incorrect." — **쿠키 없음**
정지 회원 (비밀번호 맞음)	403 `ACCOUNT_DISABLED`
칸 빠짐	422

2. 언제 쓰나

home.html 로그인 모달의 **Sign In** 버튼 → `home.js` / `auth-ui.js` (P1-07).

순서	화면 · 서버	일어나는 일
①	로그인 모달	이메일 · 비밀번호 · **Keep me signed in**
②	P1-07 JS	`api.post('/auth/login', {email, password, remember}, {auth: false})`
③	**이 라우터**	29 확인 → 27 · 31 쿠키 → 26 본문
④	P1-07 JS	`setAccessToken(access_token)` (JS 01) → 헤더가 My Page · My Projects 로 바뀜 → `next` 페이지로 이동 (JS 05)

3. 코드

import (파일 맨 위)

```
from typing import Annotated

from fastapi import APIRouter, Cookie, Query, Response, status
from pydantic import EmailStr

from app.api.deps import Db
from app.core.config import get_settings
from app.core.security import create_access_token, create_refresh_token
from app.schemas.auth import (
    AvailabilityResponse,
    LoginRequest,
    Nickname,
    SignupRequest,
    SignupResponse,
    TokenResponse,
)
from app.schemas.common import ErrorResponse
from app.services import auth_service
```

`auth.py` 맨 위의 import 이다. **`from app.core.security import create_access_token, create_refresh_token` 을 이번에 추가했다.** 이 함수는 `Response` · `Db` · `get_settings` · 두 토큰 함수 · `LoginRequest` · `TokenResponse` · `auth_service` 를 쓴다.

함수

```
@router.post(
    "/login",
    response_model=TokenResponse,
    responses={401: {"model": ErrorResponse}, 403: {"model": ErrorResponse}},
)
def login(data: LoginRequest, response: Response, db: Db) -> TokenResponse:
    user = auth_service.authenticate(db, data.email, data.password)
    set_refresh_cookie(response, create_refresh_token(user.user_id), data.remember)
    return TokenResponse(
        access_token=create_access_token(user.user_id),
        expires_in=get_settings().jwt_access_minutes * 60,
    )
```

`@router.post(…)` 와 함수 머리는 템플릿에 있었고, 몸통 세 줄을 채웠다.

문법 풀이

import 문법	뜻
`from app.core.security import A, B`	26 · 27 의 토큰 함수 두 개를 가져옴

식	뜻
`response: Response`	FastAPI 가 넣어 주는 응답 객체. 여기에 쿠키를 붙이면(31) 최종 응답 헤더에 실림

식	뜻
`data: LoginRequest`	본문 `{email, password, remember}` (`remember` 는 없으면 `False`)
`TokenResponse(access_token=…, expires_in=1800)`	응답 본문. `token_type` 은 기본값 `"bearer"`

4. 흐름

1. 29 `authenticate()` — 틀리면 여기서 401 · 403 로 끝남 (쿠키도 토큰도 만들지 않음).
2. 27 로 리프레시 토큰 → 31 로 쿠키에 담음 (`remember` 에 따라 3일 · 세션).
3. 26 으로 Access Token → 본문으로 200.

5. 왜 이렇게

선택	이유
확인을 맨 먼저	실패하면 토큰 · 쿠키를 만들지 않는다. 시험에서 실패 응답에 `Set-Cookie` 가 없음을 확인했다
Access 는 본문, Refresh 는 쿠키	27 §5 — 짧은 토큰은 JS 가 쓰고, 긴 토큰은 JS 가 못 보게 숨긴다
`expires_in` 을 줌	화면이 "몇 초 뒤 만료" 를 알 수 있다. 지금 `api.js` 는 401 을 받으면 재발급하므로 쓰지 않지만, 미리 재발급하는 방식으로 바꿀 때 쓸 수 있다
이메일 형식 검사 (`EmailStr`)를 하지 않음	로그인 칸에 형식이 틀린 이메일을 넣어도 422 가 아니라 401 "Email or password is incorrect." 하나로 답한다. 무엇이 틀렸는지 알려 주지 않는 원칙(29)과 같다

6. 시험 (`tests/test_auth_routes.py` 에 7개 추가 · 모두 34개, 실제 앱 + MySQL)

가입(22)으로 회원을 만든 뒤 로그인했다.

시험	확인한 것
200 본문	칸이 `access_token` · `token_type` · `expires_in` 셋뿐 (리프레시 토큰 없음), `bearer` · 1800, 05 로 읽으면 그 회원 번호
쿠키 (체크 · 안 체크)	`snx_refresh=…; HttpOnly; Path=/api/v1/auth`, 체크면 `Max-Age=259200`, 안 체크면 없음. 쿠키 값을 28 로 읽으면 그 회원 번호
마지막 로그인	`last_login_at` 이 기록됨
비밀번호 틀림 · 없는 이메일	둘 다 401 · 같은 본문, `Set-Cookie` 없음
비밀번호 칸 빠짐	422

전체 시험 225개 통과, `ruff` 검사 통과. 시험 뒤 남은 행 0개.